

Duckworks AI Governance Readiness Assessment

— Executive Case Study

Executive Overview

Duckworks is a fictional European technology and advanced manufacturing company employing approximately 1,200 staff. The company designs and produces mechanical and robotic arms engineered specifically for ducks and is expanding the use of artificial intelligence across engineering, manufacturing, customer service, supply-chain management, employee productivity, and recruitment.

As part of its **Project W.I.N.G. — Workflows, Intelligence, Next-Generation Governance** transformation program, Duckworks identified a need to establish a formal AI governance capability before AI adoption became fragmented across the organization.

The purpose of this project was to design an enterprise-level AI governance foundation that enables innovation while ensuring that AI systems are identified, assessed, controlled, monitored, and supported by appropriate governance evidence.

Business Objectives

Duckworks' primary objectives are to:

- Enable responsible adoption of AI across business and technical functions.
 - Establish a centralized inventory of approved and discovered AI systems.
 - Introduce a consistent methodology for identifying and assessing AI risks.
 - Define clear ownership, accountability, approval, and escalation responsibilities.
 - Integrate AI governance with existing cybersecurity, privacy, enterprise risk, compliance, and internal-audit processes.
 - Identify AI systems requiring enhanced governance based on their intended purpose and potential impact.
 - Prevent uncontrolled or inappropriate use of public generative-AI services.
 - Create an auditable governance structure capable of supporting management assurance and future regulatory obligations.
 - Balance governance requirements with Duckworks' objective of continuing rapid AI experimentation and innovation.
-

Scope

The assessment covered seven AI use cases across Duckworks:

1. **DuckDesign AI** — generative engineering and mechanical-arm design assistance.

2. **QuackBot** — generative AI customer-service and product-support chatbot.
3. **FeatherForecast** — predictive demand, inventory, and supply-chain forecasting.
4. **WingInspect Vision** — computer-vision-based manufacturing defect detection.
5. **DuckTalent AI** — AI-assisted applicant screening, ranking, and recruitment support.
6. **PondGPT** — internal generative-AI productivity and knowledge assistant.
7. **Unregistered GenAI Usage** — employee use of external generative-AI tools outside formal governance processes.

The project considered governance, cybersecurity, privacy, fairness, human oversight, operational resilience, product safety, third-party dependency, regulatory exposure, data governance, and assurance requirements.

Detailed technical penetration testing, model-development validation, legal opinions, certification activities, and production implementation were outside the scope of the initial readiness assessment.

Key Assumptions

The assessment was conducted using a fictional organization, fictional systems, synthetic data, and publicly available regulatory and framework information.

The following assumptions were applied:

- Duckworks operates primarily within the European market.
- AI systems may process confidential company information, intellectual property, customer information, employee data, or applicant data depending on their intended purpose.
- Human decision-makers retain formal accountability for consequential engineering, employment, procurement, quality, and customer decisions.
- Duckworks uses a combination of internally developed AI capabilities and third-party AI services.
- Existing information-security and enterprise-risk processes are available but have not yet been fully adapted to AI-specific risks.
- AI governance maturity is at an early stage and no comprehensive enterprise AI control framework existed before this project.
- Regulatory applicability must be determined separately for each AI system based on intended purpose, organizational role, jurisdiction, and implementation details.
- Duckworks' internal risk classifications are enterprise risk-management decisions and are not equivalent to legal classifications such as a “high-risk AI system” under the EU AI Act.

Key Findings

The assessment identified a significant difference in risk exposure across Duckworks' AI portfolio.

DuckTalent AI represents the most significant governed AI use case. Its role in screening, comparing, ranking, and recommending employment candidates creates substantial concerns relating to fairness, discrimination, transparency, privacy, human oversight, explainability, and regulatory classification. Its

current residual risk was assessed as **Critical**, and deployment should remain subject to enhanced governance and formal approval.

Unregistered generative-AI usage represents the most immediate governance weakness. Employees are assumed to be using external AI services without consistent approval, contractual review, information-classification controls, logging, or centralized oversight. This creates material risks involving confidential information, intellectual property, personal data, and third-party exposure.

PondGPT and QuackBot introduce significant generative-AI security risks. Prompt injection, retrieval poisoning, excessive permissions, data leakage, hallucinations, and inappropriate reliance on generated outputs require dedicated technical and procedural controls.

DuckDesign AI and WingInspect Vision create potential product and safety consequences. Incorrect AI-generated engineering recommendations or failures to identify manufacturing defects could affect product quality and safety. Human review, validation, traceability, change control, and model-performance monitoring are therefore essential.

FeatherForecast presents comparatively lower risk. Its primary impacts are operational and financial rather than directly affecting individual rights or product safety. It remains subject to data-quality, model-drift, monitoring, and human-oversight requirements.

Across the portfolio, the assessment found that AI risk cannot be managed effectively through cybersecurity controls alone. Effective governance requires coordinated ownership across technology, information security, risk and compliance, legal, privacy, HR, business operations, and internal audit.

Governance Response

The project established the foundation for a structured Duckworks AI governance program consisting of:

- An enterprise AI system inventory.
- A cross-functional AI Governance Committee.
- Defined first-, second-, and third-line responsibilities.
- An AI Risk Classification and Assessment Methodology.
- Inherent, residual, and target risk assessment concepts.
- AI-specific control and evidence requirements.
- Regulatory and framework applicability analysis.
- Enhanced governance requirements for higher-impact systems.
- Formal treatment of shadow and unregistered AI use.
- Reassessment triggers for material system, model, vendor, data, or intended-purpose changes.

The governance design draws on recognized sources including the NIST AI Risk Management Framework, ISO/IEC 42001, ISO/IEC 23894, ISO/IEC 42005, ISO/IEC 27001, applicable European legislation, and recognized AI cybersecurity guidance.

Overall Conclusion

Duckworks can continue pursuing broad AI adoption, but the assessment indicates that **governance intensity should be proportional to the potential impact of each AI system rather than applying the same approval process to every use case.**

The organization should prioritize governance controls for DuckTalent AI, unmanaged generative-AI use, PondGPT, QuackBot, and AI systems capable of influencing product safety.

The recommended operating model therefore combines centralized governance standards with risk-based assessment, documented human accountability, technical controls, continuous monitoring, and independent assurance.

The objective is not to prevent Duckworks from using AI. It is to ensure that the organization can answer five fundamental questions for every material AI system:

What is the system doing? Who is accountable for it? What can go wrong? What controls are operating? Can Duckworks prove those controls are effective?

Duckworks, its employees, AI systems, data, risks, and business activities are fictional and were created exclusively for educational and professional portfolio purposes.